LAB ASSIGNMENT REPORT

Course: Web Security & Penetration Testing | Assignment: DAY56-OSINT-FUNDAMENTALS

DAY 56

Jiwosh Shrestha

Q1–Q3 — DEFINITION, LEGAL/ETHICAL BOUNDARIES, SCOPE (9 MARKS)

Q1 — Definition and limits [3]

OSINT (Open-Source Intelligence) is the disciplined collection and analysis of information from publicly available sources to answer a defined intelligence question. Sources include websites, public records, social media, news, academic publications and other material that does not require unauthorised access.

Three things OSINT is not: (1) Not hacking — it does not involve exploiting systems, bypassing access controls or using stolen credentials. **(2) Not covert surveillance —** it does not mean installing malware, tracking devices without authority, or intercepting private communications. **(3) Not unrestricted data scraping of personal data for harassment or stalking —** ethical OSINT stays inside legal authority, documented scope and respect for privacy expectations.

Q2 — Legal and ethical boundaries [3]

Prohibited actions and why they are out of scope: (1) Unauthorised access to accounts or systems — illegal under computer-misuse laws and outside any OSINT mandate. **(2) Social engineering or pretexting to obtain non-public information —** deceptive collection that violates consent and often organisational policy. **(3) Doxxing or publishing private personal data to harm someone —** unethical and may breach data-protection and harassment laws. **(4) Ignoring terms of service or robots rules where they clearly prohibit bulk harvesting for the intended use —** creates legal and reputational risk. Training exercises use only fictional subjects and public demonstration data.

Q3 — Scope [3]

Elements of a collection plan: (1) Intelligence requirement — the specific question to answer. **(2) Subject and identifiers —** who/what is in scope (names, domains, handles), explicitly excluding what is out of scope. **(3) Source list —** categories and priority of sources to consult. **(4) Time box —** start/end dates and depth limits so collection does not expand indefinitely. **(5) Legal/ethical constraints —** applicable laws, organisational policy, and prohibited techniques. **(6) Recording standard —** how evidence is captured (URL, timestamp, screenshot/hash) so findings remain auditable. **(7) Output format —** who receives the product and in what structure.

LAB ASSIGNMENT REPORT

Course: Web Security & Penetration Testing | Day 56
Sources, Collection & Analysis

DAY 56

Jiwosh Shrestha

Q4–Q6 — SOURCES, COLLECTION VS ANALYSIS, CONFIDENCE AND BIAS (9 MARKS)

Q4 — Sources [3]

Four source categories: (1) Official / government records — strengths: authoritative, often structured; weaknesses: lag, limited fields, jurisdiction gaps. **(2) News and media —** strengths: timely context, secondary confirmation; weaknesses: editorial bias, errors, paywalls. **(3) Social media and user-generated content —** strengths: real-time signals, networks of association; weaknesses: impersonation, deleted content, privacy settings, high noise. **(4) Technical sources (DNS, WHOIS, certificate transparency, public code repos) —** strengths: factual infrastructure data, historical logs; weaknesses: privacy redaction, spoofable fields, incomplete coverage. Good practice mixes categories so no single weak source drives a conclusion.

Q5 — Collection vs analysis [3]

Collection gathers raw material; analysis turns it into assessed judgements. They must be separated so that analysts do not selectively collect only what supports a preferred narrative, and so that raw evidence remains available for re-examination. **Evidence recording:** for each item note source URL or locator, collection timestamp (UTC), collector identity, a stable copy or cryptographic hash of the content, and a short description of relevance. Analysis notes are stored separately and clearly labelled as interpretation, not fact. This audit trail supports peer review and later challenges to the product.

Q6 — Confidence and bias [3]

Confidence levels (e.g. high / medium / low) express how strongly the evidence supports a statement, based on source reliability and corroboration — not on how strongly the analyst feels. Corroboration means independent sources agreeing on the same fact; a single blog post is weaker than three independent official records. **Two biases: (1) Confirmation bias —** favouring information that supports an existing hypothesis and downplaying contradictions; mitigated by actively seeking disconfirming evidence. **(2) Availability bias —** over-weighting easily retrieved or recent information; mitigated by structured source lists and time-boxed review of less convenient records.

Q7 — PRODUCT STRUCTURE (2 MARKS)

Q7 — Product [2]

Structure of a short OSINT report: (1) Header — title, requirement reference, date, classification/handling, author. **(2) Scope and caveats —** what was asked, what sources were used, time window, and explicit limits (fictional subject, public sources only). **(3) Key judgements —** concise assessed answers to the intelligence question, each with a confidence level. **(4) Evidence summary —** facts supporting each judgement, with source citations (URL + timestamp). **(5) Gaps and uncertainties —** what could not be established and what would change the assessment. **(6) Sources appendix —** full list of materials consulted. Judgements and evidence stay clearly separated so a reader can see both the conclusion and the basis for it.

Key takeaways

- OSINT = public sources + defined question + recorded evidence — not hacking or covert access.
- Separate collection from analysis; state confidence; actively counter confirmation and availability bias.
- Training uses fictional subjects only; stay inside legal and organisational boundaries.